Readings:

- AWS Whitepaper Single Sign On
- Federating Google Cloud with AD
- FIDO UAF overview
- Google Cloud Setup Checklist
- RFC6749 OAuth2.0

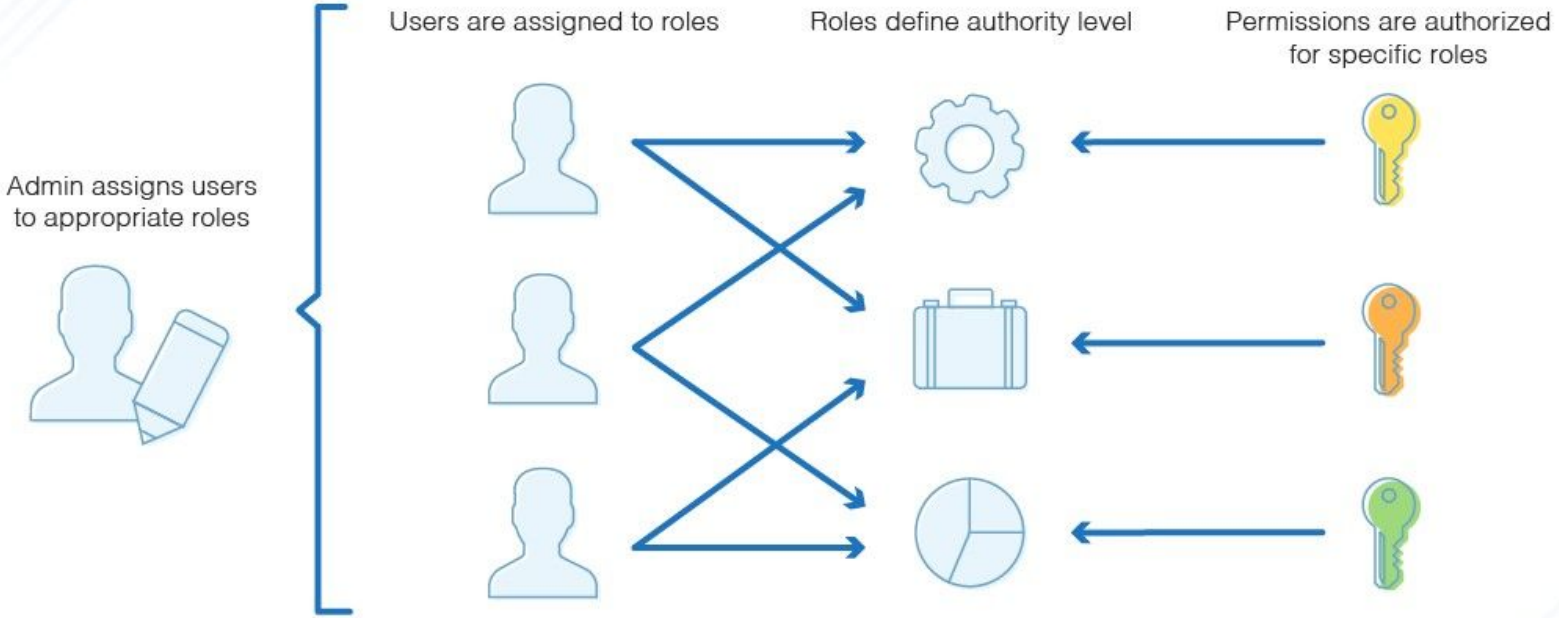
Lecture 2: Identity in the Cloud

Lucerne University of
Applied Sciences and Arts
HOCHSCHULE
LUZERN

Overview

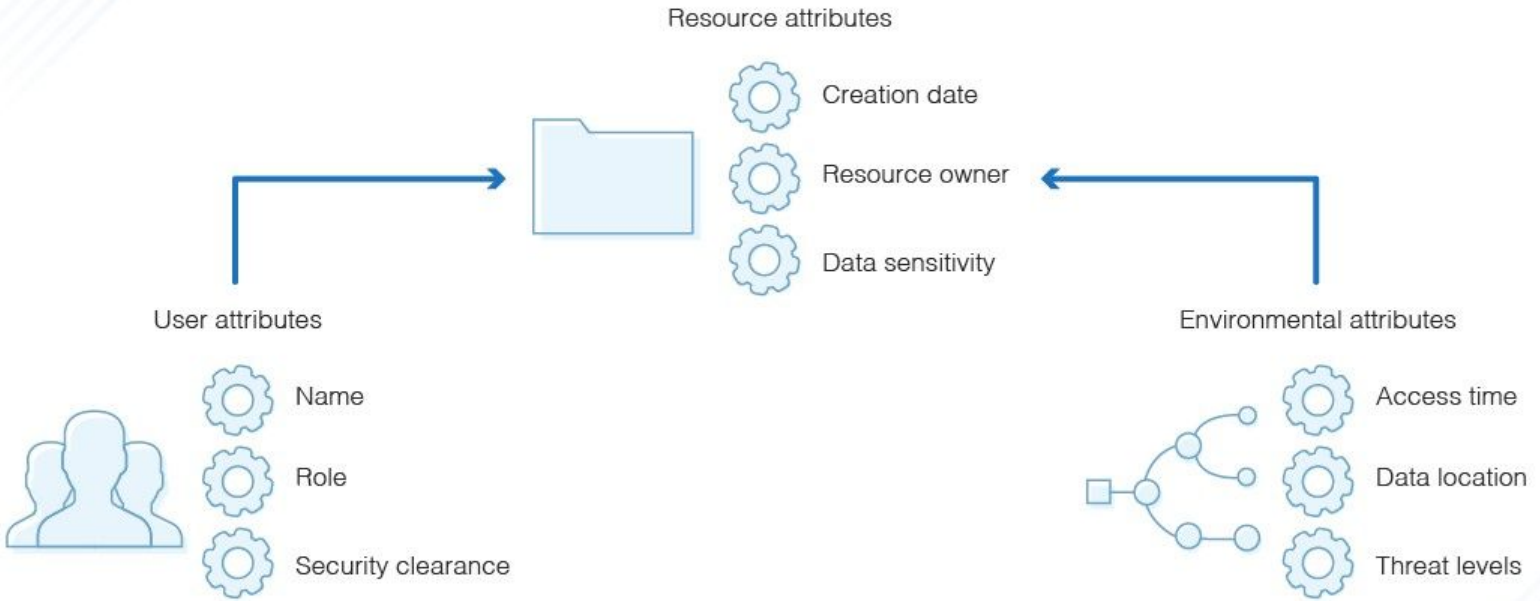
- Cloud IAM
- Federated Identity Management
- OAuth2.0 / SAML / Open ID Connect

Role-Based Access Controls



Source: https://www.dnsstuff.com/rbac-vs-abac-access-control

Attribute-Based Access Control



Source: https://www.dnsstuff.com/rbac-vs-abac-access-control

The Identity Question in Cloud

- Who
- Can do What
- On Which Resource

The Identity Question in Cloud: **Who**

- Authentication of the subject
  - For example:
    - User Account
    - Group
    - Service Account
    - Cloud Identity Domain
- Multi Factor Authentication recommended
  - U2F (Universal 2nd Factor)
    - open standard - strengthens and simplifies two-factor authentication using specialized Universal Serial Bus or near-field communication devices similar to smart card tech
- Audit trail
  - Control / Monitoring Centre
  - Integrate logs to external entity (e.g. publish to SIEM)



https://cloud.google.com/security/products/titan-security-key

The Identity Question in Cloud: **Who**

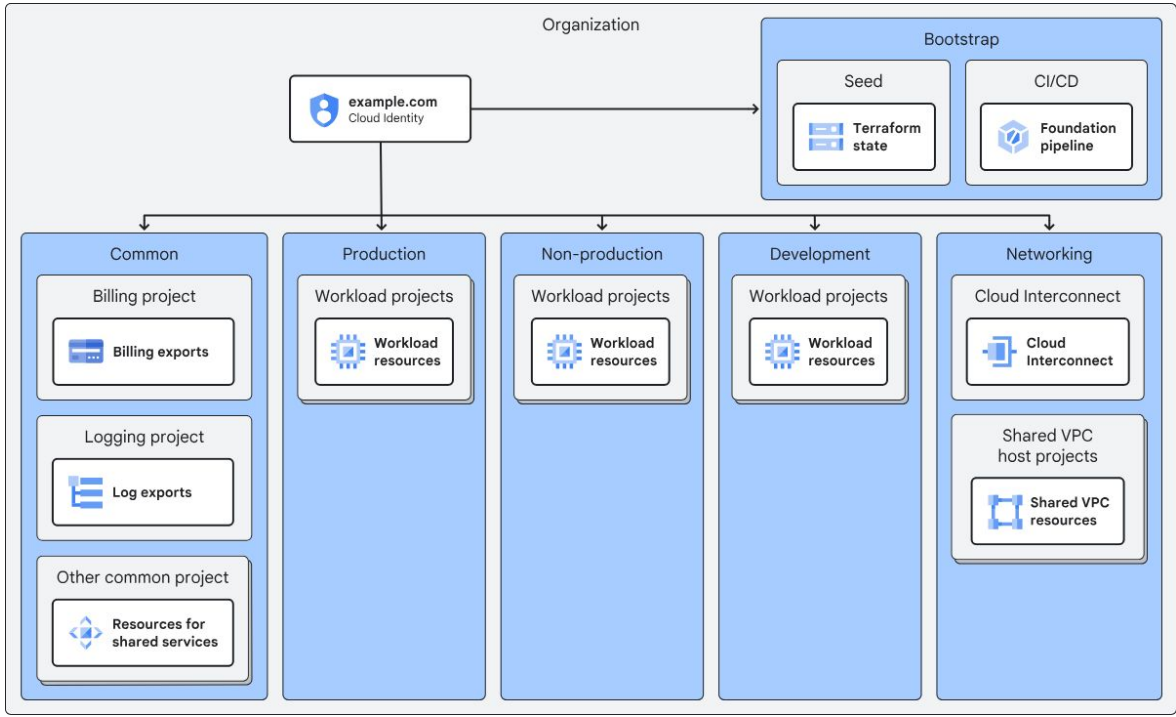
- Roles
  - Primitive roles
    - GCP provides **Owner, Editor, Viewer**
  - Finer grained roles
    - **Predefined roles** exist
  - Custom roles
    - Defining a precise set (project or org levels, not folder level)
    - Service account could be created to authenticate VM to storage service
- Connection to existing Identity and Access Management repositories
  - For example
    - Active Directory
    - GCIAM

The Identity Question in Cloud: Can do **What**

- Actions of the subject
  - For example
    - **Create** instance
    - **Delete** instance
    - **Start** instance
    - **Stop** instance
    - **Change** instance

The Identity Question in Cloud: **On Which Resources**

- Scope of the subject
  - For example:
    - Organisation
    - Folder
    - Project
- Inheritance from Organisation to Folder to Project
  - Principle of least privilege



https://docs.cloud.google.com/architecture/blueprints/security-foundations/organization-structure

Azure Identity Management

- Microsoft Entra ID (formerly Azure AD) is the Azure solution for identity and access management.
- Entra ID is a multitenant, cloud-based directory and identity management service from Microsoft.
- It combines core directory services, application access management, and identity protection into a single solution.

AWS Identity and Access Management (IAM)

- AWS Identity and Access Management (IAM) is a web service from Amazon Web Services (AWS) for managing users and user permissions in AWS.
- Outside the AWS cloud, administrators of corporate systems rely on the Lightweight Directory Access Protocol (LDAP) to manage identities.
- By using role-based access control (RBAC) and Security Assertion Markup Language (SAML) 2.0 corporate IT systems administrators can bridge the IAM and LDAP systems and simplify identity and permissions management across on-premises and cloud based infrastructures.

AWS Identity and Access Management (IAM)

- Identity federation2 supports SAML 2.0. so that instead of recreating existing user data in AWS, users in an organization can access AWS, where SAML is used to federate user identities into AWS.

Cloud Identity and Access Management (IAM)

- Cloud Identity and Access Management (IAM) lets administrators authorize who can take action on specific resources, giving full control and visibility to manage Google Cloud resources centrally.
- For enterprises with complex organizational structures, hundreds of workgroups, and many projects, Cloud IAM provides a unified view into security policy across the entire organization, with built-in auditing to ease compliance processes.
- Cloud IAM provides tools to manage resource permissions easily and in an automated way. Job functions within the company can be mapped to groups and roles. Users get access only to what they need to get the job done, and admins can easily grant default permissions to entire groups of users.

Cloud Identity and Access Management (IAM)

- Cloud IAM enables granting of access to cloud resources at fine-grained levels, well beyond project-level access.
  - Can create more granular access control policies to resources based on attributes like device security status, IP address, resource type, and date/time.
  - These policies help ensure that the appropriate security controls are in place when granting access to cloud resources.
- Built in audit trails
  - A full audit trail history of permissions authorization, removal, and delegation gets surfaced automatically for your admins.
  - Helps with compliance / evidencing.

Cloud Identity

- Cloud Identity is the Google Cloud built-in managed identity service
- Used to easily create or sync user accounts across applications and projects.
- Functions include to provision and manage users and groups, set up single sign-on, and configure two-factor authentication (2FA) directly from the Google Admin Console.
- Resource Manager is used to centrally manage projects, whereby Cloud Identity enables access to the Google Cloud Organization for this purpose.

Service Accounts

https://youtu.be/xXk1YlkKW_k?si=ii_Bn1LtPivmdbzD

- Service accounts are a special kind of account typically **used by an application or compute workload**, such as a Compute Engine instance, **rather than a person**.
- A service account is **identified by its email address, which is unique to the account**.
- Applications use service accounts to make authorized API calls by authenticating as either the service account itself, or as Google Workspace or Cloud Identity users through domain-wide delegation.
- When an application authenticates as a service account, it has access to all resources that the service account has permission to access.
- The most common way to let an application authenticate as a service account is to attach a service account to the resource running the application.
    - **For example, you can attach a service account to a Compute Engine instance so that applications running on that instance can authenticate as the service account. Then, you can grant the service account IAM roles to let the service account—and, by extension, applications on the instance—access Google Cloud resources.**

https://cloud.google.com/iam/docs/service-account-overview

Service Accounts: Identities for Apps, Not People

The Core Concept

A **Service Account** is a special type of Google account intended to represent a non-human user—like an application, a virtual machine, or a script—that needs to authenticate and be authorized to access data in Google APIs.

How it Works

- **Identity & Resource:** It acts as an **identity** (has an email address) but is also a **resource** (you can control who has permission to "act as" the account).
- **Authentication:** Instead of a password, SAs use **RSA keys** or **short-lived tokens** to prove their identity.
- **Authorization:** You grant **IAM Roles** to the service account to define exactly what it can do (e.g., "Read from Cloud Storage").

The "Golden Rule"

> **"Users** login with passwords to use the Console; **Applications** use Service Accounts to talk to APIs."

Service Account Example: Automating Data Processing

The Scenario

You have a **Cloud Function** that triggers whenever a user uploads a photo. The function needs to resize the image and save a record in a **Firestore** database.

The Service Account Workflow

1. **The Identity:** You create a service account named image-processor@my-project.iam.gserviceaccount.com.
2. **The Permissions:** You grant this account two specific roles:
    - Storage Object Viewer (to read the original photo).
    - Datastore User (to write the metadata to Firestore).
3. **The Attachment:** You "attach" this service account to the **Cloud Function**.
4. **The Execution:** When the code runs, it doesn't use *your* personal credentials; it automatically "assumes the identity" of the service account to perform its tasks securely.

The Security Benefit

Least Privilege in Action: If your Cloud Function code is ever compromised, the attacker only gains access to "Read Photos" and "Write Data"—they cannot delete your entire project or access your billing info because the Service Account wasn't given those permissions.

Authentication and Access Control

- Google Cloud uses **Google Cloud Identity** for authentication and access management.
- Manually maintaining Google identities for each employee can add unnecessary management overhead when all employees already have an account in an existing identity store such as **Active Directory**.
- By **federating** user identities between Cloud Identity and Active Directory, the maintenance of Google identities can be automated, and their lifecycle tied to existing identity management processes within the organization

https://services.google.com/fh/files/misc/google-cloud-security-foundations-guide.pdf

Google Cloud Directory Sync tool

- Relevant users and groups are synchronized periodically from Active Directory to Cloud Identity using the Google Cloud Directory Sync tool.
- This process ensures that when a new user is created in Active Directory, that user can be referenced in Google Cloud.
- This process also ensures that if a user account is deleted or suspended, those changes are propagated.
- Provisioning works **one way**, which means changes in Active Directory are replicated to Cloud Identity but *not* the other way around.
- The sync process does not include passwords: in a federated setup, Active Directory remains the only system that manages these credentials.

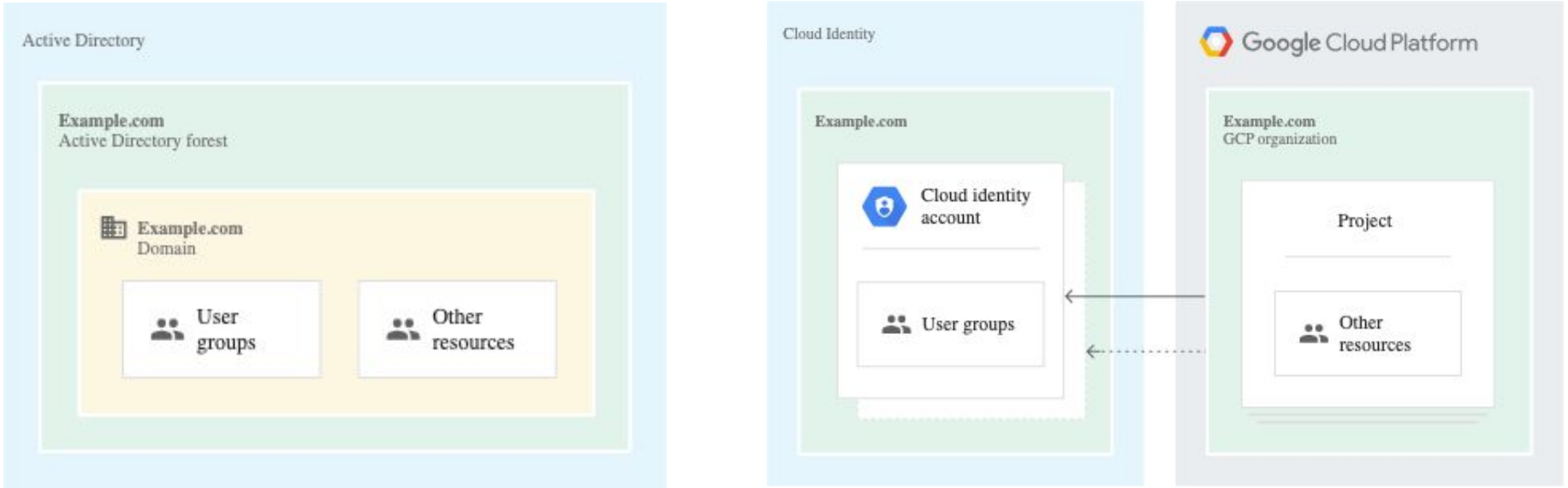
https://docs.cloud.google.com/architecture/blueprints/security-foundations

Quiz 3

- How is RBAC useful in cloud environments?
- What cloud object hierarchy elements might you expect to apply access controls to?
- How does inheritance work for the access controls?
- Compare the service account construct in GCP, AWS and Azure (identities of non-human entities)



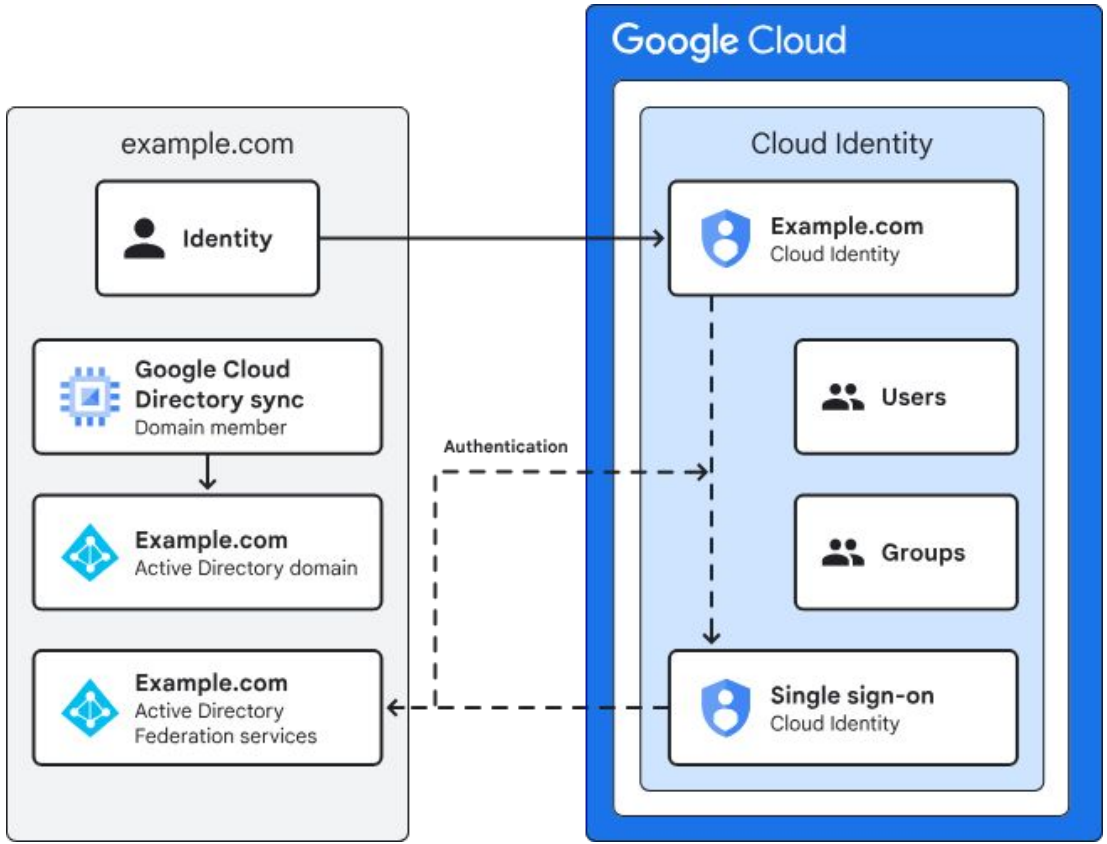
Separate Worlds … AD / Cloud Identity



But how to bridge these worlds!

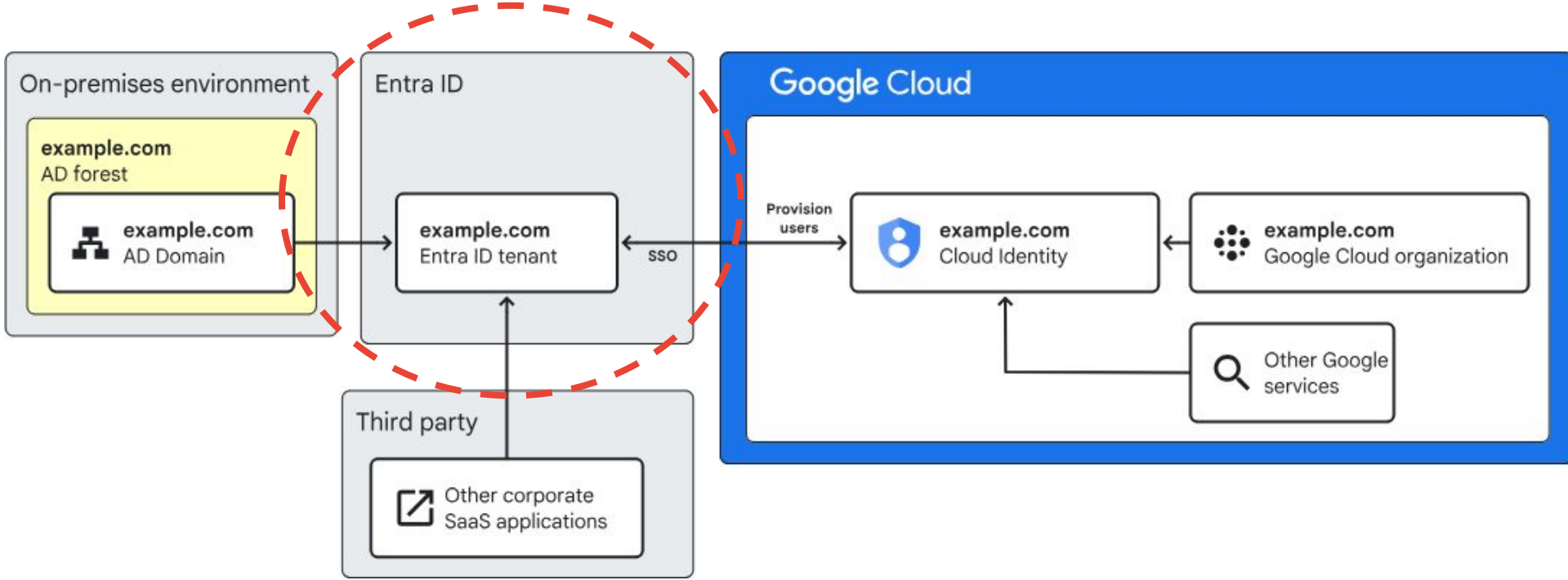
https://cloud.google.com/architecture/identity/federating-gcp-with-active-directory-introduction

Setting up Federation between AD and Cloud Identity



https://docs.cloud.google.com/architecture/blueprints/security-foundations/authentication-authorization

Setting up Federation involving Entra ID



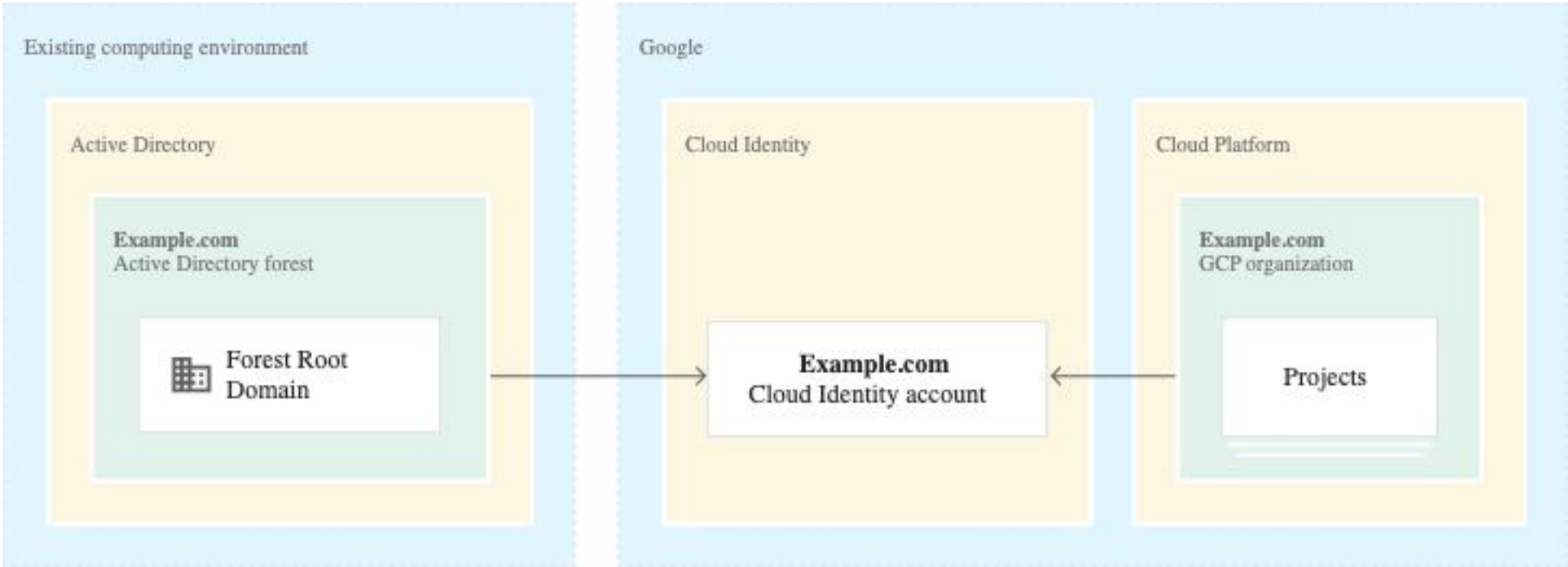
Lucerne University of
Applied Sciences and Arts
HOCHSCHULE
LUZERN

https://docs.cloud.google.com/architecture/identity/federating-gcp-with-azure-active-directory

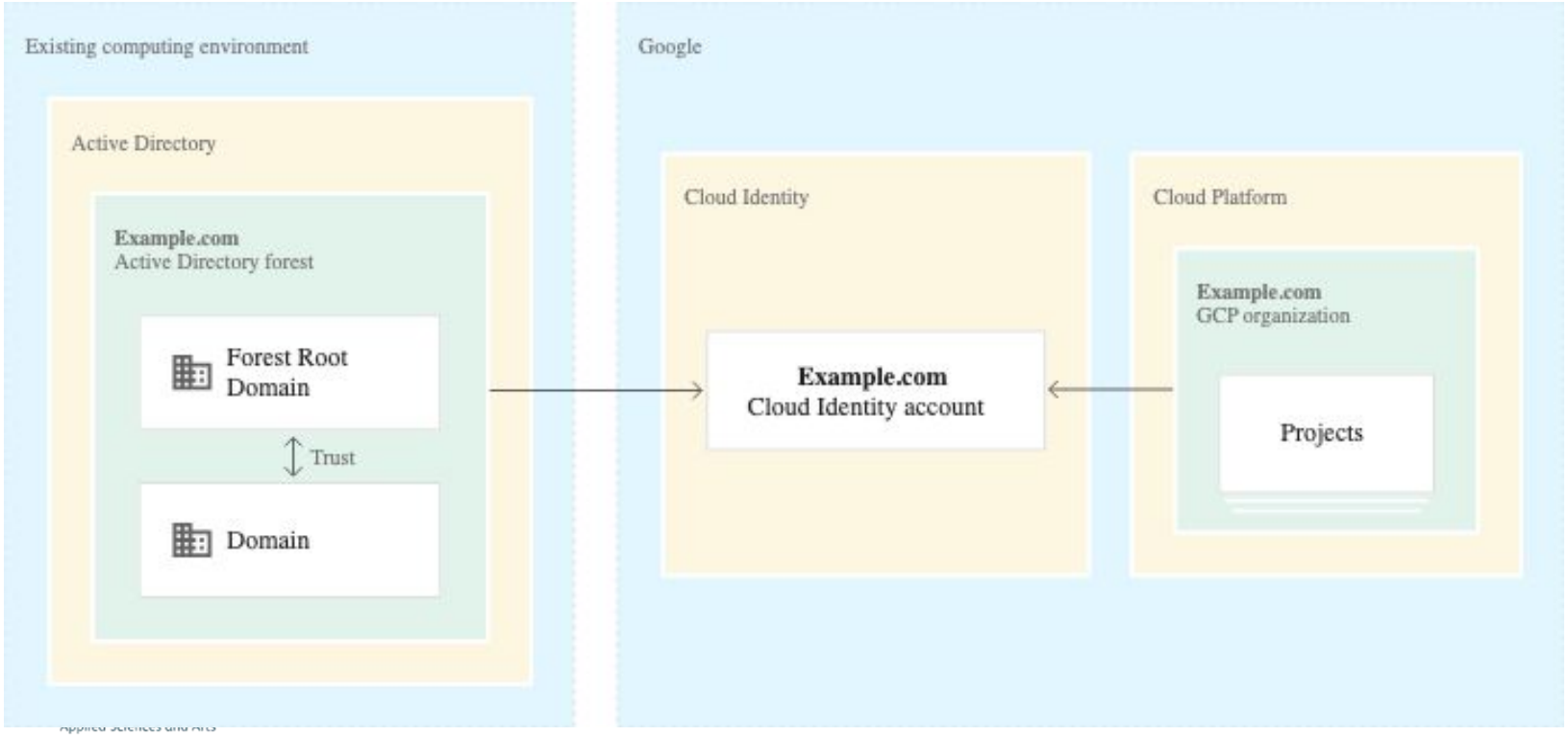
How a User Authenticates

- **Single sign-on**:
  - Whenever a user needs to authenticate, Google Cloud delegates the authentication to Active Directory by using the Security Assertion Markup Language (SAML) protocol.
  - This delegation ensures that only Active Directory manages user credentials and that any applicable policies or multi-factor authentication (MFA) mechanisms are being enforced.
  - For a sign-on to succeed the respective user must have been provisioned before.

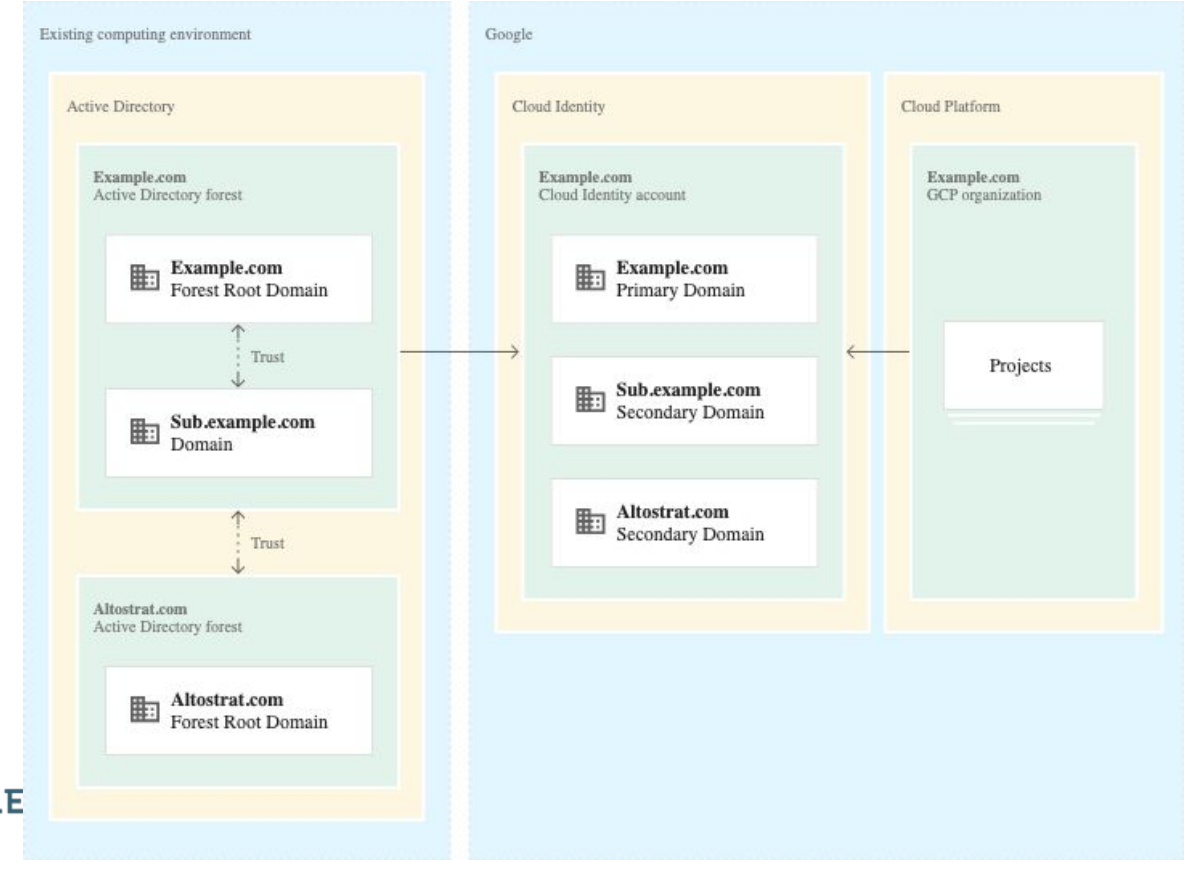
Single Forest, Single Domain



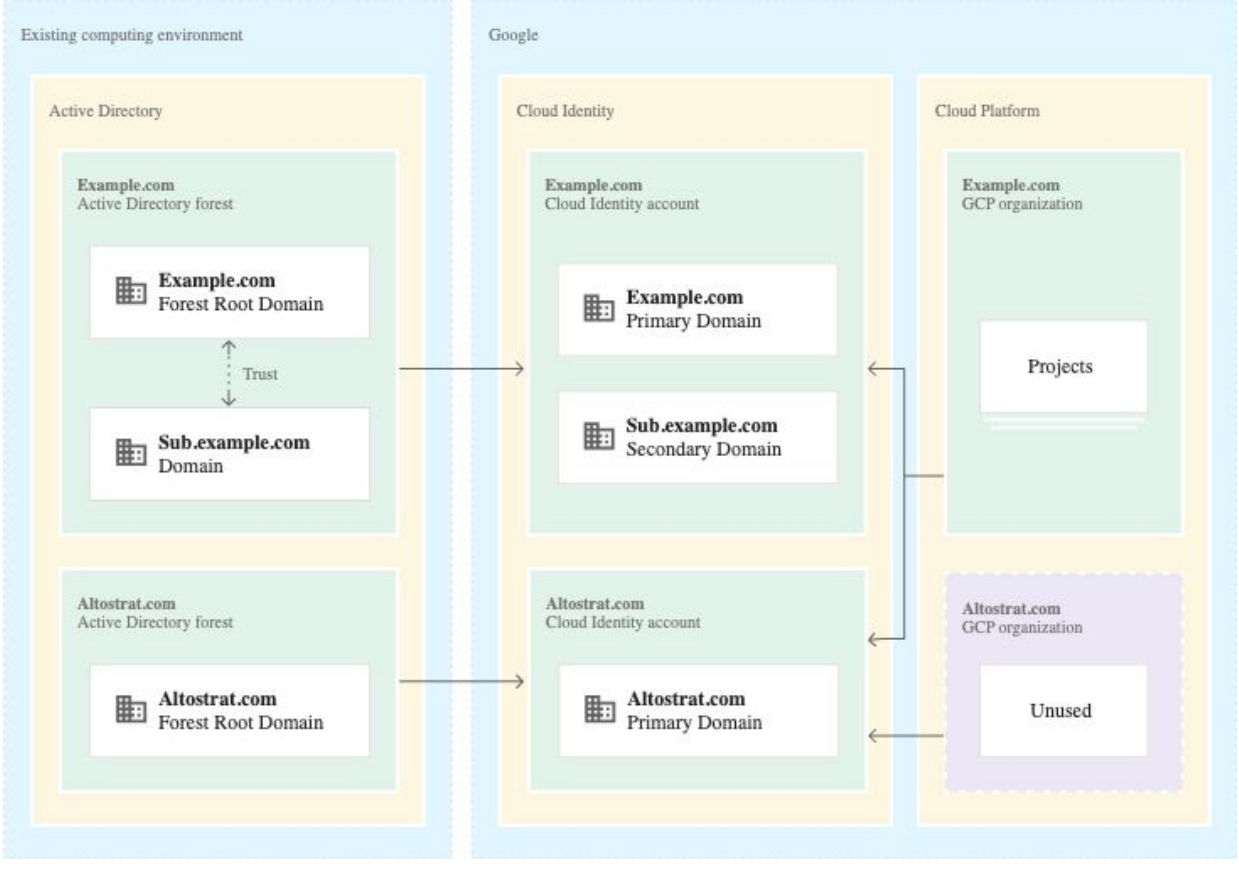
Single Forest, Multiple Domains



Multiple Forests with Cross-Forest Trust



Multiple AD forests Without Cross-Forest Trust



Setting up Google Cloud for your organisation

1. Set up or confirm an identity account
2. Add users or groups to your identity account
3. Set up administrator access to your organization
4. Set up billing
5. Set up the resource hierarchy
6. Set up access control for your resource hierarchy
7. Set up support
8. Set up your networking configuration
9. Set up logging and monitoring
10. Configure organizational security settings

GCP WORKED EXAMPLE … SIMILAR FOR OTHER CLOUDS!

1. Set up / confirm identity account

- An identity to centrally organize resources and users
- Cloud Identity is an IDaaS (Identity as a Service) solution that allows central creation and management of users and groups who can access cloud resources
- Need a Cloud Identity account to establish a Google Cloud organization + create org controls and structure

2. Add users and groups to your identity account

- Who does this? The person who will act as identity administrator for Google Cloud for company
- What to do? Add users to Cloud Identity account, who will participate in tasks. Create a set of Google Groups. Add users to the Google Groups.
- Why necessary? Creating these user accounts and groups is a requirement for assigning Cloud Identity and Access Management (Cloud IAM) roles in order to control access later
- At least one user required for following groups:
  - **gcp-organization-admins** (organize structure of resources used by org)
  - **gcp-network-admins** (create networks, subnets, firewall rules, nw devices like cloud routers, Cloud VPN instances, load balancers)
  - **gcp-security-admins** (establish and manage security policies of entire org. including access management and organization constraint policiesi)
  - **gcp-billing-admins** (set up billing accounts and monitor usage)
  - **gcp-devops** (create or manage end-to-end pipelines that support continuous integration and delivery, monitoring and system provisioning)
  - **gcp-developers** (responsible for designing, coding, testing applications)

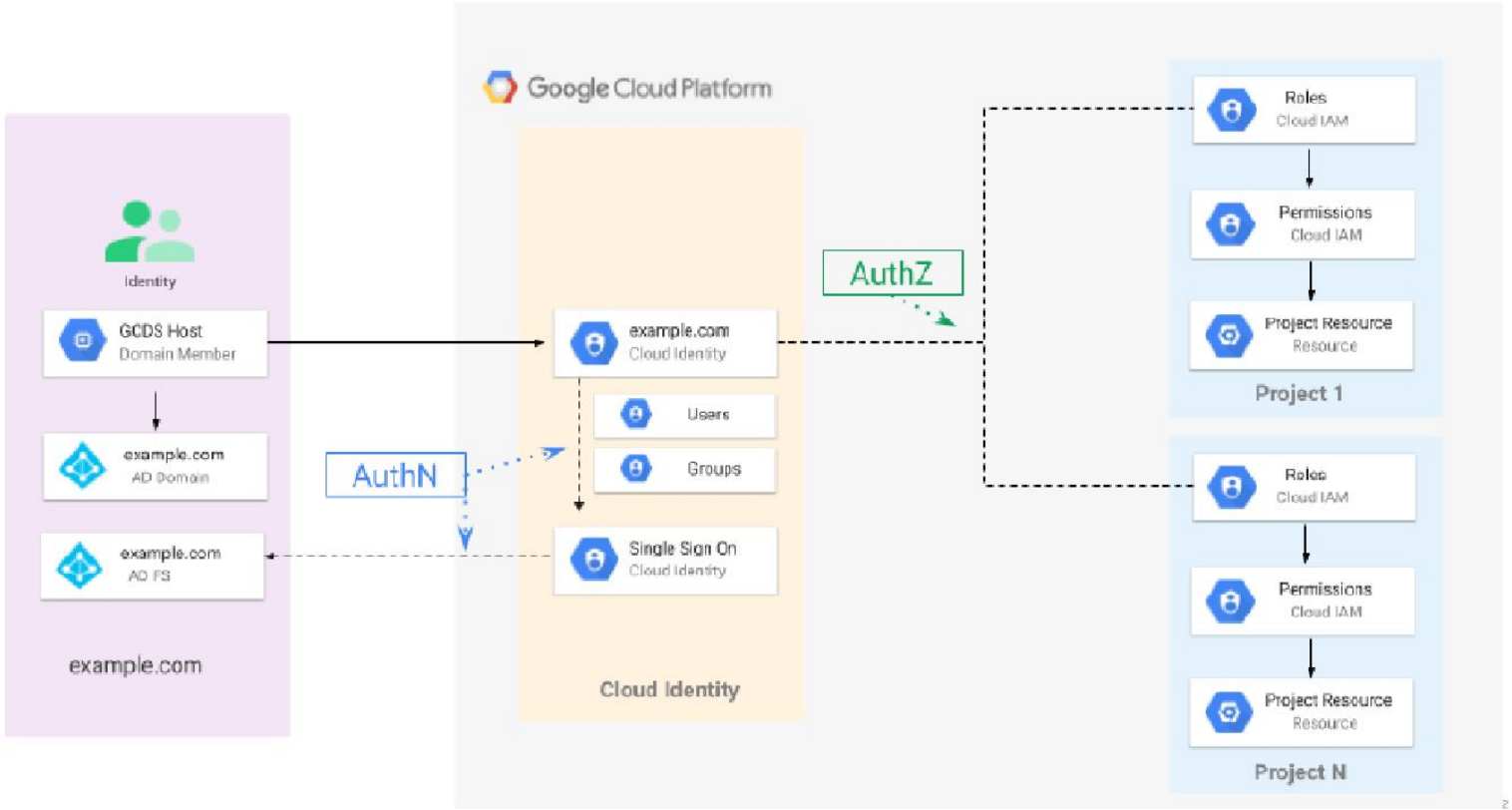
Sample groups

Group	Description	Roles	Scope
grp-gcp-billing-viewer@example.com	Members are authorized to view the spend on projects. Typical members are part of the finance team.	Billing Account Viewer BigQuery Data Viewer BigQuery User	organization for Billing Account Viewer billing project for BigQuery Data Viewer and BigQuery User
grp-gcp-platform-viewer@example.com	Members have the ability to view resource information across the Google Cloud organization.	Viewer	organization
grp-gcp-security-reviewer@example.com	Members are part of the security team responsible for reviewing cloud security.	Security Reviewer	organization
grp-gcp-network-viewer@example.com	Members are part of the networking team and review network configurations.	Compute Network Viewer	organization
grp-gcp-audit-viewer@example.com	Members are part of an audit team and view audit logs in the logging project.	Logs Viewer Private Logs Viewer Bigquery Data Viewer	logging project
grp-gcp-scc-admin@example.com	Members can administer Security Command Center.	Security Center Admin Editor	SCC project

Establishing an AD Federation

- Desirable to use Single Sign On (SSO) for user authentication
- When an AD federation is established, Google Cloud delegates authentication to the Active Directory Federation Service using the Security Assertion Markup Language (SAML) protocol
- This delegation ensures only AD manages user credentials and any applicable policies or MFA mechanisms are enforced
- For sign-on to succeed, user must be provisioned in both AD and Cloud Identity

Identity structure example



Active Directory Sync 1/2

- In the example the on-prem Active Directory is used as the source of truth for users, groups and SSO
- Cloud Directory Sync is installed on a domain-joined host on-prem (Windows or Linux)
- A scheduled job (Task Scheduler/ Cron) is used to synchronize users and groups intro Cloud Identity on an hourly basis
- To control which users are sync-ed to Cloud Identity an attribute is added to the users in AD and the Directory Sync filters on that attribute
- For example GCP specific groups could be prefixed with grp-gcp- … and a filter is applied to sync only those groups
- See example filters next

Active Directory Sync 2/2

- Example filter applied to AD for use with Cloud Directory Sync

Filter type	Filter rule
Group filter	`(&(objectCategory=group)(cn=grp-gcp-*))`
User filter	`(&(objectCategory=user)(msDS-cloudExtensionAttribute1=googlecloud))`

Table 2.12 Google Cloud Directory Sync user and group filters

3. Set up administrator access to your organisation

- Assign administrator roles to **gcp-organization-admins** group created in step 2
- Assign administrative roles to yourself (identity account) to enable performing of later roles
- Gives administrators central visibility and control over every Google Cloud resource that belongs to your organization

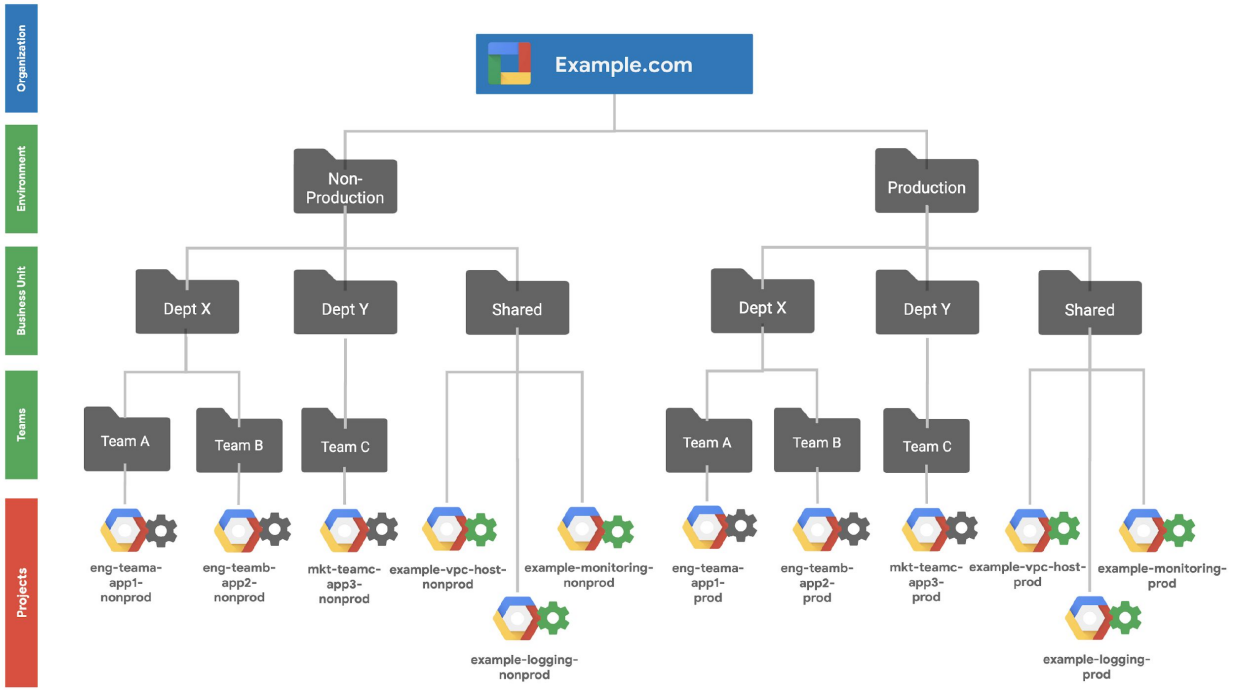
4. Set up billing

- Set up a billing account to pay for Google Cloud resources and set admin access for billing accounts
- Assign admin roles to the **gcp-billing-admins** group created in task 2
- Choose and set up a billing account type and payment method
- Cloud Billing accounts are linked to one or more Google Cloud projects and used to pay for resources used e.g. VMs, networking, storage
- Cloud Identity and Access Management (Cloud IAM) roles control access to Cloud Billing accounts

5. Set up resource hierarchy

- Create a basic structure for folders and projects in the resource hierarchy
  - Folders: provide a group mechanism, and isolation between projects (e.g. could represent main departments in org, or production vs. non-production etc.)
  - Projects: lowest level in hierarchy. Contain cloud resources (e.g. VMs, databases, storage buckets)
- Performed by a person in the **gcp-organization-admins** group created in task #2
- See diagram … distribution of load across resources

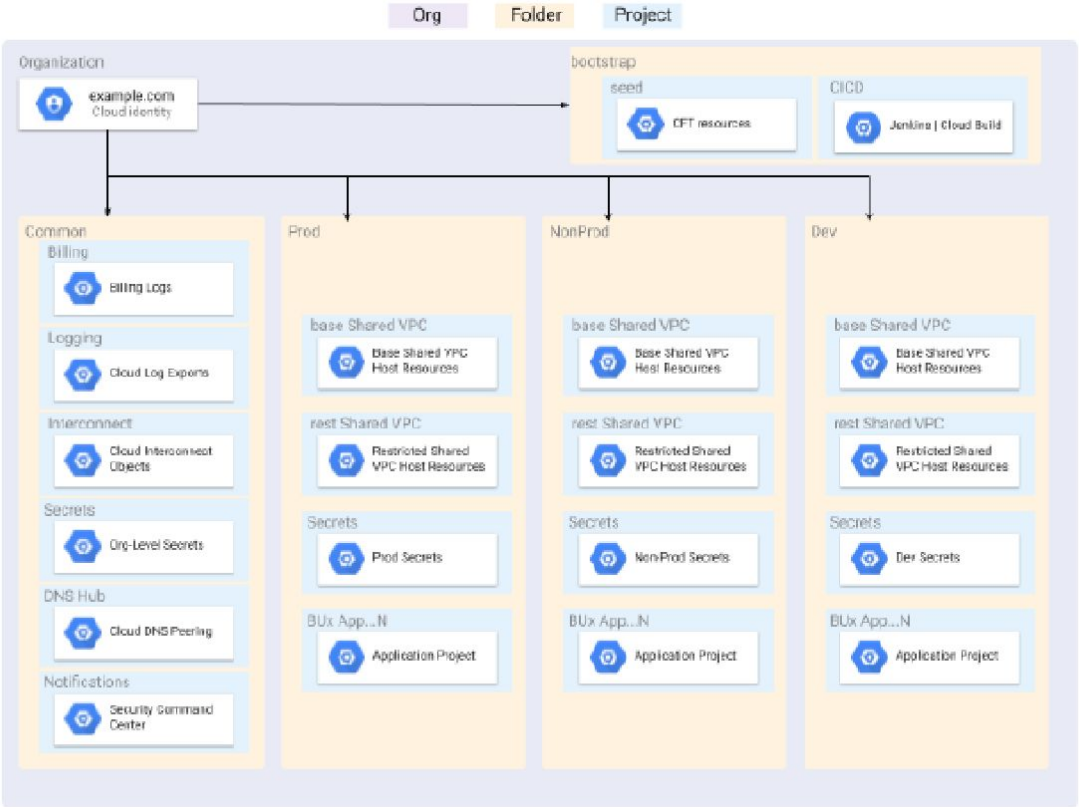
Sample Cloud Resource Hierarchy



6. Set up access control for the resource hierarchy

- Add Cloud IAM policies to the resources
  - Cloud IAM policy = a collection of statements which define who has what type of access
  - A policy is attached to a resource and used to enforce access control whenever that resource is accessed
- To set permissions, same procedure is applied for resources at different hierarchy levels: Organisations, Folders, Projects
  - Principle of least privilege is recommended!
- Done by a person in **gcp-organization-admins** created in task #2
- Policies at Org level apply to all Folders and Projects in the Org (e.g. roles to gcp-network-admins, gcp-security-admins, gcp-devops)
- Policies at Folder level also apply to Projects in Folders (e.g add gcp-devops, gcp-developers)
- Policies at Project level apply only to the projects they are applied to. Fine-grained permissions for individual projects (e.g. gcp-network-admins, gcp-devops)

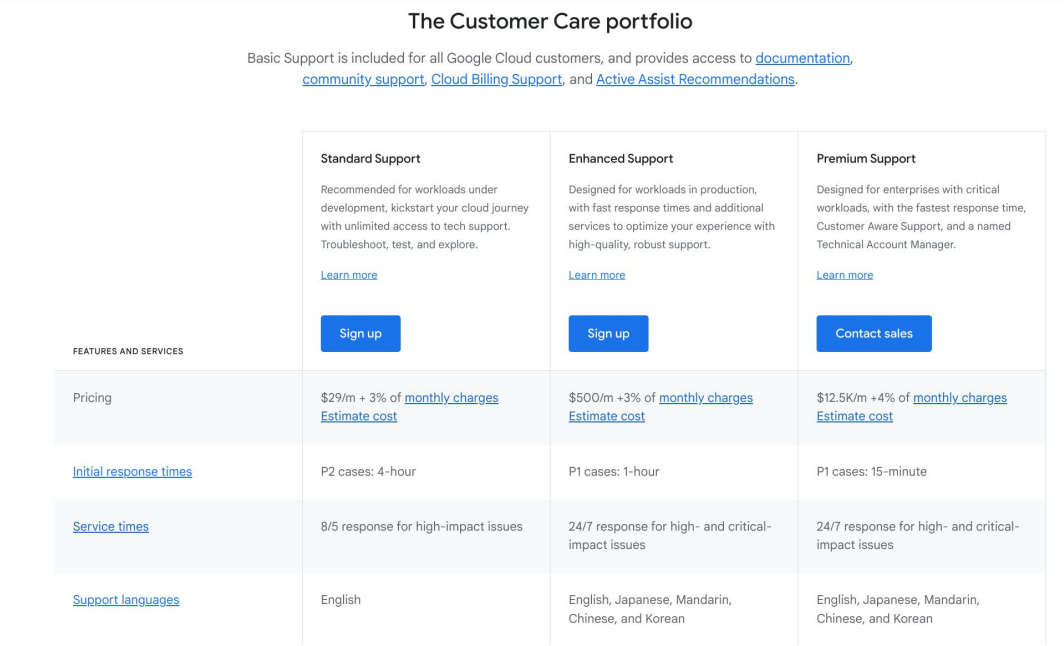
Example organizational structure



https://services.google.com/fh/files/misc/google-cloud-security-foundations-guide.pdf

7. Set up support

- Choose a support plan based on company needs
- Premium support plan provides business-critical support to quickly resolve issues
- Performed by a person in the **gcp-organization-admins** created in task #2



The Customer Care portfolio

Basic Support is included for all Google Cloud customers, and provides access to documentation, community support, Cloud Billing Support, and Active Assist Recommendations.

FEATURES AND SERVICES	Standard Support Recommended for workloads under development, kickstart your cloud journey with unlimited access to tech support. Troubleshoot, test, and explore. Learn more Sign up	Enhanced Support Designed for workloads in production, with fast response times and additional services to optimize your experience with high-quality, robust support. Learn more Sign up	Premium Support Designed for enterprises with critical workloads, with the fastest response time, Customer Aware Support, and a named Technical Account Manager. Learn more Contact sales
Pricing	$29/m + 3% of monthly charges Estimate cost	$500/m +3% of monthly charges Estimate cost	$12.5K/m +4% of monthly charges Estimate cost
Initial response times	P2 cases: 4-hour	P1 cases: 1-hour	P1 cases: 15-minute
Service times	8/5 response for high-impact issues	24/7 response for high- and critical-impact issues	24/7 response for high- and critical-impact issues
Support languages	English	English, Japanese, Mandarin, Chinese, and Korean	English, Japanese, Mandarin, Chinese, and Korean

See: https://cloud.google.com/support

8. Set up networking configuration

MORE ON THIS IN LECTURE #5

- Create shared VPC networks: Design, create and configure a virtual private cloud architecture
  - Shared VPC allows several teams to connect to a common, centrally managed VPC network from multiple distinct products.
- Configure Connectivity: If on-prem networking exists, or networking in another cloud provider, configure connectivity between that provider and Google cloud
- Set up a path for external egress traffic
- Implement network security controls e.g. firewall rules
- Choose preferred ingress traffic option for services hosted on the cloud
- Performed by a person in the **gcp-network-admins** group created in task #2

Virtual Private Cloud Architecture



https://console.cloud.google.com/getting-started/enterprise;step=NETWORKING

9. Set up logging and monitoring

MORE ON THIS IN LECTURE #6

- Set up basic logging and monitoring features using Cloud Logging and Cloud Monitoring
- Performed by a person in **gcp-devops** created in task #2
- Comprehensive logging and monitoring is key to maintaining observability in the cloud environment
- Appropriate logging retention establishes an audit trail and can create a central dashboard for viewing environments
- Cloud monitoring collects metrics, events and metadata from Google Cloud services, hosted uptime probes, application instrumentation and other common app components
- Cloud logging allows to store, search, analyze, monitor and alert on log data and events from Google Cloud. Also allows to ingest custom log data from any source, and to export logs to external data sinks.

10. Configure organizational security settings

- Done by a person in **gcp-organization-admins**
- Enable the Security Command Centre dashboard
  - SCC performs cloud native security management and compliance monitoring to address data risks, vulnerabilities and threats
- Set up Organisational Policy
  - The Organization Policy Service provides centralized and programmatic control over the organization's cloud resources

MORE ON THIS IN LECTURE #7

SAML vs OAuth vs OpenID Connect

SAML 2.0



ENTERPRISE SSO

XML-based federation standard designed for cross-domain Single Sign-On in enterprise networks.

Primary Focus: Federated User Authentication

Data Format: XML Assertions

Best Suited: Legacy corporate Web Apps & identity providers (IdPs)

OAuth 2.0



DELEGATED ACCESS

Authorization framework granting applications limited access to user resources without password sharing.

Primary Focus: Delegated Authorization

Data Format: JSON / Bearer Tokens

Best Suited: REST API security & scoping

OpenID Connect



MODERN IDENTITY LAYER

Identity profile layer extension built on top of OAuth 2.0 to verify identity and deliver profile claims.

Primary Focus: Authentication + AuthZ

Data Format: JSON Web Tokens (JWT)

Best Suited: Modern Web, Mobile & SPAs

https://www.parallels.com/blogs/ras/?s=OAuth

SAML

SAML 2.0 is an open standard for passing authentication and authorization information among three actors, namely, the principal, the service provider and the identity provider.

- Principal = the user
- Service provider = owner of a web resource
- Identity provider = performs identity access management services.

Most SAML implementations today still support the previous version, SAML 1.1, for backward compatibility.

SAML 2.0: Heavyweight Enterprise Federation

XML-Based Assertions
Carries digitally signed XML identity payloads directly through front-channel browser redirects.

Strict Metadata Trust
Requires manual X.509 certificate exchange between Identity Provider (IdP) and Service Provider (SP).

Enterprise Backbones
Dominates legacy B2B SaaS, corporate Active Directory / ADFS integrations, and government portals.

SAML OPERATIONAL CONSTRAINTS

High XML Overhead: Verbose payloads consume significant bandwidth.

Poor Mobile Fit: Browser redirects fit desktops but struggle in native app views.

No Native API Security: Lacks standardized REST authorization mechanics.

SAML

SAML leaves it to the identity provider to use a suitable authentication method, though it recommends implementation of transport-level security and message-level security.

The standard enforces the use of XML-based messages to pass information between the service provider and the identity provider.

Known as security assertions, these messages can be of any of three types, namely:

- **Authentication statements:** An assertion that confirms to the service provider that the identity provider has authenticated a principal.
- **Attribute statements:** Contains one or more attributes, or name-value pairs, on the basis of which access is given to the principal.
- **Authorization decision statements:** An assertion that a principal can perform one or more actions once they have access to the web resource provided by the service provider.

SAML purposely limits what the parties can perform with XML assertions. The XML-based Extensible Access Control Markup Language (XACML) can be used for fine-grained access control.

OAuth 2.0: Delegated API Access Control

01. Resource Owner

The end user who grants access to their protected resources or data assets.

02. Client

The application making resource requests on behalf of the user with consent.

03. Auth Server

Issues access tokens after authenticating user and verifying permission scopes.

04. Resource Server

The API hosting protected assets; validates access tokens before returning data.

OAuth 2.0 is strictly an Authorization framework. An access token tells the API what permissions are granted, NOT who the user is.

OAuth

OAuth is an open standard for authorization that grants secure delegated access to applications, devices, application programming interfaces (APIs) and servers via **access tokens**.

OAuth authorizes an application to access your data without giving it access to your credentials.

Prior to OAuth, HTTP basic authentication was the most commonly used form of gaining access to systems, requiring only the use of a username and password.

OAuth Abstract Protocol Flow (RFC6749)



OpenID Connect: Identity Layer Over OAuth 2.0

OIDC = OAuth 2.0 + ID Token

Adds standardised user authentication & profile retrieval on top of token authorization.

ID Token (JWT)

Signed JSON Web Token containing identity assertions: Subject ID, Issuer, Auth Time, and Nonce.

UserInfo Endpoint

Protected REST API endpoint returning verified profile claims (email, name, picture, roles).

Dynamic Discovery (JWKS)

Standardized `.well-known` configuration and automated public key rotation. Enables knowledge of identity provider settings.

OpenID Connect (OIDC)

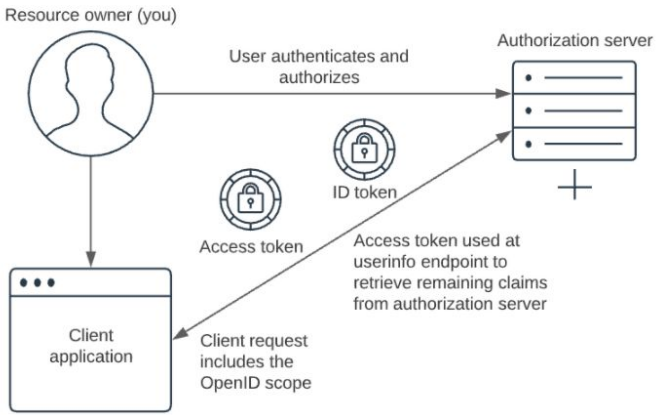
Based on the OpenID decentralized authentication protocol, OpenID Connect provides an authentication layer on top of OAuth 2.0. It **addresses the lack of an authentication mechanism in OAuth**, which is a weakness when it comes to authorizing sensitive transactions such as payments.

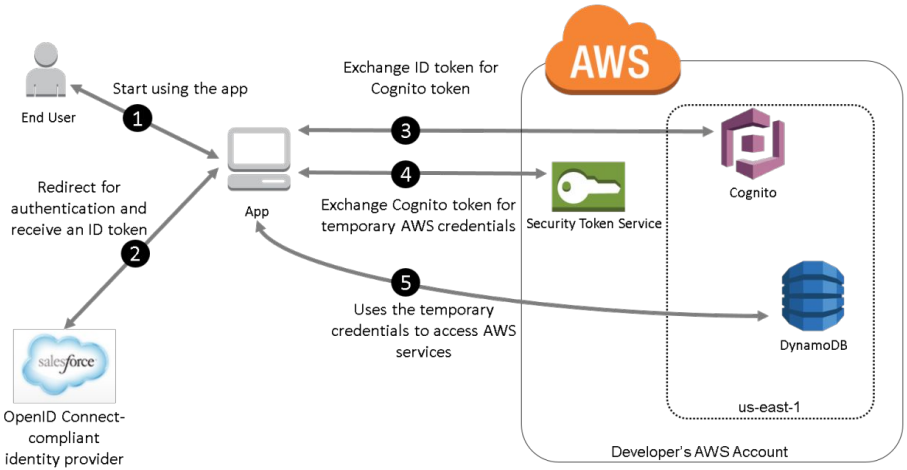
A typical OpenID Connect workflow involves three parties, namely, the **client**, the **end user** and the **identity provider.**

- The **client**, or the Relying Party, sends the **end user** to the **identity provider**, where the end user authenticates the identity and authorizes access to the client.
- The **identity provider** sends an authorization code to the **client**, which then uses it to request access and ID tokens from the **identity provider.**
- Once the client gets the tokens, it is allowed to perform an action on behalf of the end user.

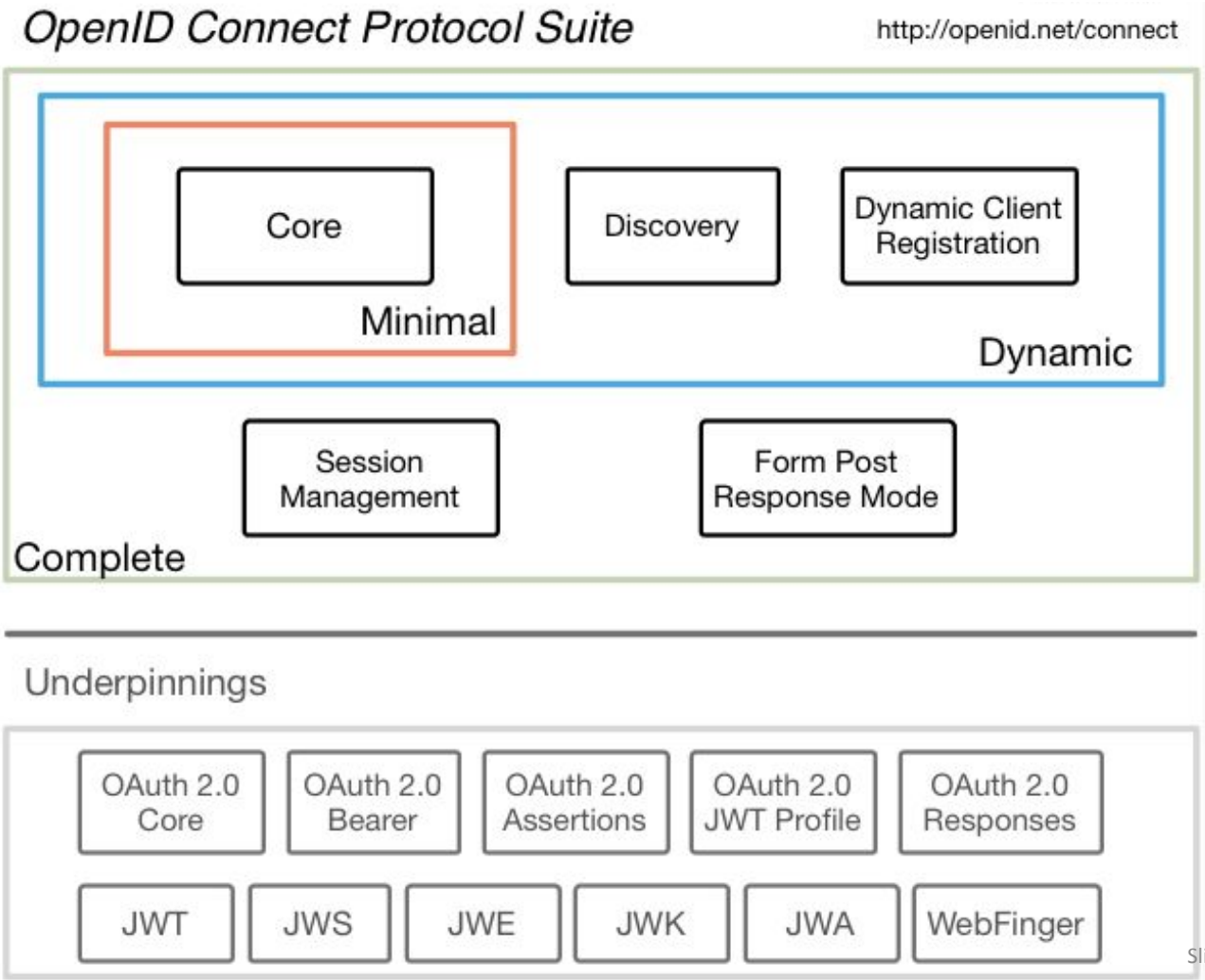
OpenID Connect uses a signed and cryptographically verifiable JSON Web Token to ensure that the access and ID tokens are not tampered with during the exchange of information between parties.

OIDC Conceptual / AWS Specific Flows





https://www.linkedin.com/pulse/oidc-what-openid-connect-how-does-work-you-need-know-omar-ismail/


OpenID Connect Protocol Suite
http://openid.net/connect
Core
Minimal
Discovery
Dynamic Client Registration
Dynamic
Session Management
Form Post Response Mode
Complete
Underpinnings
OAuth 2.0 Core
OAuth 2.0 Bearer
OAuth 2.0 Assertions
OAuth 2.0 JWT Profile
OAuth 2.0 Responses
JWT
JWS
JWE
JWK
JWA
WebFinger

TECHNICAL SPECIFICATION

Side-by-Side Architectural Comparison

Feature	SAML 2.0	OAuth 2.0	OpenID Connect (OIDC)
Primary Goal	Federated Web SSO	Delegated API Authorization	Federated AuthN + User Info
Data Payload	XML Assertions	JSON / Opaque Bearer Tokens	JSON Web Tokens (JWT)
Transport Method	HTTP POST / Front-Channel Redirect	HTTP Headers (Authorization: Bearer)	Front-Channel + Back-Channel Calls
Client Types	Web Browsers / Web Apps	APIs, Microservices, Mobile Apps	SPAs, Mobile, Server Side, Devices
Key Management	X.509 Certificate Exchange	Client Secret / Private Key JWT	Automated JWKS Key Endpoints

Protocol Coexistence in Enterprise Ecosystems

SAML 2.0 → **Workforce SSO Federation Layer**
Authenticates corporate employees against legacy Enterprise IdPs (Okta, Ping, ADFS).

OIDC → **Modern Application Authentication**
Verifies user identities across customer-facing Single-Page Apps (SPAs), mobile clients, and SaaS apps.

OAuth 2.0 → **Microservice & API Security**
Passes scoped access tokens to backend microservice mesh to enforce granular resource authorization.

DECISION MATRIX

Protocol Selection Guide: When to Use What

Choose SAML 2.0

When building or integrating:

- Legacy Enterprise SSO
- Strict B2B compliance requirements
- Existing Active Directory infrastructure

Choose OpenID Connect

When building or integrating:

- Mobile & Single-Page Apps (SPAs)
- Modern Greenfield Customer Portals
- "Social Login" (Google, Apple, Linkedin, ,,,)

Choose OAuth 2.0

When building or integrating:

- Third-party API authorization
- Service-to-service Machine Auth
- Fine-grained scope protection

To The Future: OAuth 2.1 & Passkeys

OAuth 2.1 Hardening

Consolidates OAuth 2.0 best practice security specs into a single streamlined standard.

PKCE Mandatory: Required for all authorization code flows.
Deprecated Flows: Eliminates vulnerable Implicit & Password grants.
Strict Redirect URIs: Mandatory exact string matching.

Passkeys / FIDO2 / WebAuthn

Replaces passwords with phishing-resistant public-key cryptography embedded in device hardware.

Phishing Proof: Cryptographically bound to domain origin.
Complements OIDC: Passkeys act as the local *authenticator* inside OIDC.
Hardware Security: Uses device Secure Enclave / TPM.

Continuous Identity & Zero Trust Architecture

CAEP / Shared Signals (SSF)

Continuous Access Evaluation Protocol (CAEP) enables real-time token revocation across SaaS apps when user risk profile changes mid-session.

Verifiable Credentials (VC)

Decentralised identity standard allowing users to cryptographically store and present verified identity claims without central IdP lookups.

ZERO TRUST SHIFT

From "Authenticate Once at Edge" to "Continuously Verify Everywhere"



Lucerne University of
Applied Sciences and Arts
HOCHSCHULE
LUZERN

Practical Usage in Identity Architectures

1. **Protocols Are Not Competitors:** SAML handles enterprise legacy, OIDC manages user login, and OAuth 2.0 secures APIs. Mature stacks use all three.

2. **Default to OIDC for Greenfield Builds:** Use OpenID Connect with PKCE for all new web, mobile, and single-page applications.

3. **Never Use Plain OAuth for Authentication:** Plain OAuth 2.0 access tokens lack standard identity assertions and present major security risks if misused for login. Use for AuthZ not AuthN!

4. **Prepare for Modern Hardening:** Enforce OAuth 2.1 recommendations and pair OIDC authentication with Passkeys / WebAuthn for phishing resilience.

Quiz 4

- What is the difference between AuthN and AuthZ?

- Which solution would you use for:
  - Third-party API authorization
  - Legacy Enterprise SSO
  - Login using Linkedin

- What is the difference between a Cloud IAM solution and a federated identity solution?



- Use your favourite LLM to learn some more about PKCE



Glossary for Identity

- ABAC
- IAM
- LDAP
- MFA
- OAuth2.0
- OpenID Connect (OIDC)
- PKCE
- RBAC
- SAML